Personnel competency management in the security laboratory

Competence, Measured

How the laboratory decides who can be put on which work, and what that confidence actually rests on.

278	12	11	17	140
assessable skills	technical domains	career ladders	lab services	standards cited

A briefing

What the system is

1

The taxonomy

278 named activities the laboratory can be asked to perform, each with written criteria at six levels of proficiency.

2

The record

One dated, attributable assessment per person per activity, holding the evidence it rests on and the authorization it carries.

3

The decisions

Who can staff a job, what each person needs next, and which services rest on a single qualified person.

The first two stages are discipline. The third is the one the laboratory actually opens every week.

Three questions, answered from one record

Who can we put on this work?

Asked every time an engagement lands, and again whenever somebody is unavailable. It has to be answerable before the work is promised, not after.

What makes us confident they can?

Asked by clients, by partners who rely on our results, and by us. A job title is not an answer; a dated assessment against written criteria is.

Where does this person go next?

Asked at every review, and by the person themselves. The answer should be a named set of skills and a date, not an adjective.

What we want it to achieve

Staff projects

Every service we sell lists the skills it needs at the levels it needs them. Matching that against assessed people tells us who can take a job, and where only one person could.

Stand behind results

A dated, attributable assessment for each activity, with the evidence it rests on. Our method follows ISO/IEC 17025, the standard for competence in testing laboratories.

Give people direction

A distance to the next tier computed in named skills, so development is planned against evidence rather than negotiated in adjectives.

Staffing is first deliberately. It is the use that pays for the effort of keeping the records honest, and the one that would collapse first if they went stale.

Competence attaches to activities, not job titles

A job title says

Senior Analyst

An average of many different competences. It cannot tell you which work this person can take.

One record says

Illustrative competence record	
Skill	Differential power analysis
Level	**3, independent practice**
Assessed	4 March 2026, by a named evaluator
Evidence	Three engagements, reports reviewed
Authorization	**Granted, unsupervised work**
Last practiced	11 September 2026

There are 278 such activities. A person holds a separate dated record for each one they have been assessed on, and that is what the staffing and development reports read.

How a job gets staffed

1. The service

Each of the 17 services lists the competencies it needs and the minimum level for each. Hardware Security Evaluation names 20; a red team engagement names 38.

2. The project

A project opens as a copy of that template, then is tailored to the real engagement: requirements added, dropped, or set to a different level.

3. The match

Every requirement is checked against each person's assessed levels across all domains. Self-assessments are never counted here.

Service readiness, Hardware Security Evaluation

Firmware extraction	level 3	**4 people qualify**
Laser fault injection	level 2	**1 person qualifies**
Active sample preparation	level 2	**nobody qualifies**

The uncomfortable lines are the valuable ones. A requirement only one person meets is a sales risk, a holiday problem and a succession problem at once, and it is visible here before it becomes an emergency.

One ladder, two established scales

Levels 0 to 2, learning. Output is reviewed before it leaves the laboratory.

Levels 3 to 5, authorized. Work carries the laboratory's name.

0	1	2	3	4	5
None	**Awareness**	**Guided practice**	**Independent practice**	**Advanced, mentor**	**Expert, authority**
No stage	*Novice*	*Advanced beginner*	*Competent*	*Proficient*	*Expert*
Not applicable	Under training	Supervised	Authorized	Authorized, complex	Technical authority

The italic words are stages from the Dreyfus model, which describes how skill actually develops. The lines under them are authorization states from ISO 17025, which describe what the laboratory may permit. Stacking the two is the design decision.

Everything turns on the step from 2 to 3

At level 2, supervised

Everything the person produces is reviewed by an authorized colleague before it reaches a client. Their name does not carry the result.

At level 3, authorized

They plan, perform and sign off routine work alone. Nothing stands between their judgement and the client.

What has to happen in between, in this order

Supervised work on real engagements → A passed proficiency assessment → An explicit management authorization

Training alone never closes this gap. Expect most of the laboratory's development effort, and most of its frustration, to sit at exactly this boundary.

The criteria are written before the assessment

Differential power analysis, criteria at level 3

- Designs trace acquisition campaigns (trigger setup, trace count estimation, sampling parameters)
- Applies appropriate leakage models (HW, HD, identity) and selects optimal attack points
- Recovers full AES keys from unprotected and lightly protected implementations independently
- Evaluates attack results using key rank estimation and success metrics
- Produced DPA/CPA reports on 3+ real engagements meeting lab standards

Four ways to establish a level

Controlled exercise
252
skills

Work-product review
179
skills

Problem solving
85
skills

Direct observation
46
skills

Self-assessment is heard, not counted

People rate themselves against these same written criteria. Those ratings sit beside the official level with the difference marked, and are excluded from every calculation until a manager ratifies one.

The assessor checks against a standard that already exists, so their judgement is bounded by a document they did not write that day.

The standards we track

Every one of the 278 skills carries a mapping to the NICE Framework, and most carry several more. These are twelve of the frameworks our skills map to, with the number of skills citing each.

278 NICE Framework	117 MITRE ATT&CK	44 SFIA	41 CWE	36 Common Criteria	28 GIAC
24 CREST	25 CIS Benchmarks	23 OWASP	21 CSA CCM	16 JIL attack potential	15 FIPS 140-3

140 standards cited in all, across ten groups: Common Criteria and FIPS 140-3, the NIST SP 800 series and the post-quantum FIPS 203 to 205, IEC 62443, ISO/SAE 21434 and UNECE R155, ETSI EN 303 645, and the OWASP Top 10s for ML, LLM and agentic systems. The citation counts are generated from the records, and the generator fails if any standard is cited by nothing, so an unused standard cannot sit in the list unnoticed.

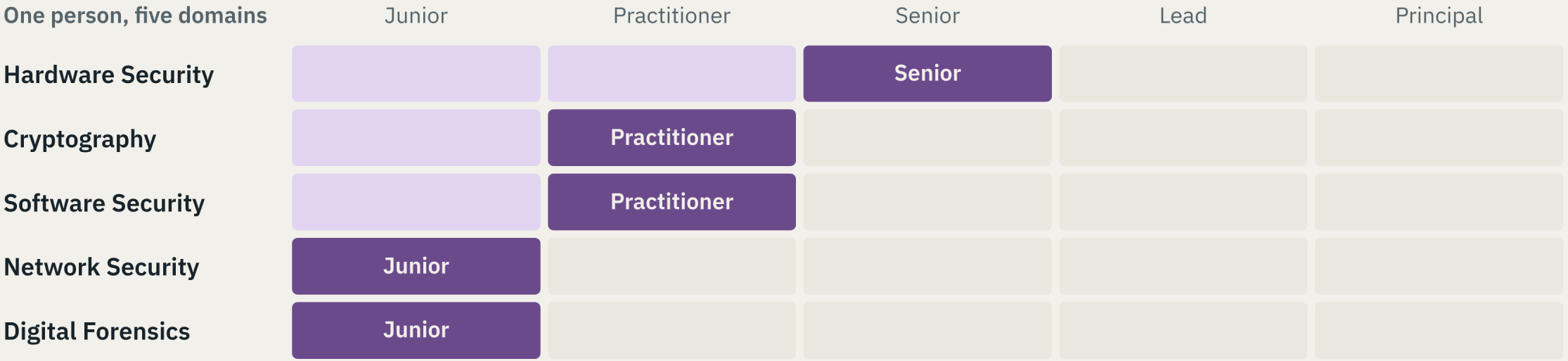
A profile sets direction. It does not describe a person

What a profile is

A ladder for one domain, with five tiers and the thresholds for each. Eleven exist. It answers one question: inside this domain, what comes next?

Why one is never enough

People accumulate skills across domains. Reading a single profile alone makes somebody look narrower than they are, and hides the cross-domain depth real engagements need.



The person above is a senior hardware evaluator. They are also a working cryptographer and a competent software reviewer, and the staffing reports read all five rows. Only development conversations narrow to one.

A tier asks four questions

Deep enough?

Enough skills in this domain, held at a high enough level.

Broad enough?

Spread across enough areas of the domain, not all in one corner.

Basics solid?

Report writing, evidence handling, ethics and the rest of the foundations.

Must-haves?

The few named skills that tier requires, with no substitutions.

Four yes, and that is your tier. One no, and the report names which one.

Nothing is scored or weighted, so being exceptional at one thing cannot buy out a gap somewhere else. That matters when the gap is report writing, because the report is what the client actually receives.

Five tiers, one direction

Junior

Assists. Work is checked before it leaves the lab.

9 at level 1
5 at level 2

→

Practitioner

Plans and signs off routine work alone.

13 at level 2
7 at level 3

→

Senior

Takes complex work and reviews other people's reports.

16 at level 3
7 at level 4

→

Lead

Owns the methodology and plans the technical approach across engagements.

18 at level 3
9 at level 4

→

Principal

Technical authority. Defines direction and publishes.

18 at level 4
7 at level 5

Lead and Principal are both technical tiers

Each requires technical project management and client communication at level 3, because running an evaluation and briefing a client are part of the technical work. Principal extends Lead rather than branching from it: the same requirements, with more depth behind them.

The figures are hardware security. Counts scale with domain size, so a 14-skill domain asks for 7 where a 49-skill one asks for 23, but the shape never changes: Principal repeats Lead's count and Senior's count, each one level higher. Advancing is mostly the same skills deepening, not more skills.

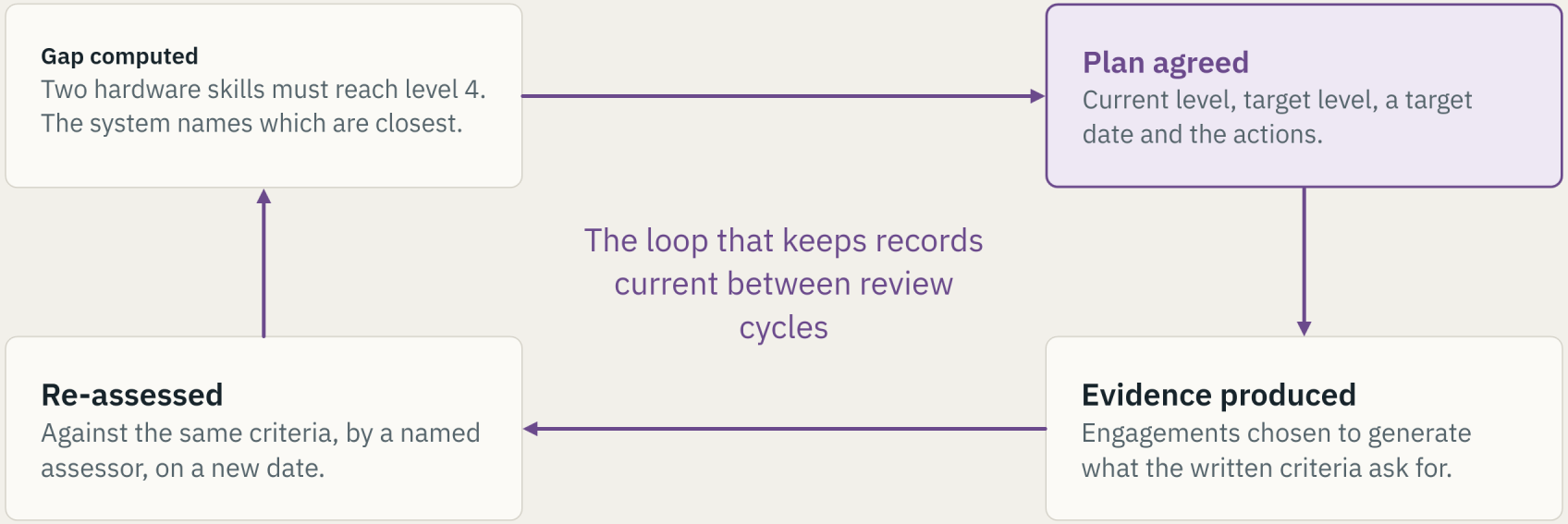
A worked example

An illustrative evaluator is considered for Senior Hardware Security Evaluator. They are strong, and they do not get it.

Gate	Required	Held	Result
Hardware skills at level 3 or above	16	17	Met
Hardware skills at level 4 or above	7	5	Short by 2
Categories held at level 2 or above	4	5	Met
Foundations average	1.50	1.64	Met
Report writing, pinned	4	4	Met
Quality assurance, pinned	3	3	Met
Standards knowledge, pinned	3	4	Met

Six gates of seven are met. The person remains a Hardware Security Evaluator, and the system states exactly why: two more hardware skills need to reach level 4.

What the gap becomes



Because the actions trace back to written criteria, "get better at side-channel analysis" becomes "second-chair two acquisition campaigns before the end of Q3".

What the system does not measure

What it does measure

- Assessed capability, per named activity
- Breadth and depth within one domain
- Whether authorization was granted, by whom, and on what date

What it does not

- How good the work actually is
- How fast somebody is
- Judgement when an engagement goes wrong at eleven at night
- Whether a client asks for them again
- Whether colleagues want to work with them

A person can hold a Principal-level profile and still be difficult to staff. The ladder is a floor on capability, not a judgement of contribution, and it should never be the only input to a performance conversation.

Known compromises, stated plainly

Thresholds are one template, not per-domain evidence

One proportional template scaled to each domain's size, with an identical foundations bar in all eleven. Not calibrated per domain, and not validated against outcomes.

Levels are ordinal, and we average them

Level 4 is not twice level 2. The foundations average works as a gate and would be indefensible as a score.

Decay is recorded but not applied

Nothing reduces a level that has gone three years unpracticed. Only a person reading the dates will notice.

Breadth against depth is not codified

Somebody senior in two domains may be judged beyond both. That call is real, it is made, and nothing in the system records or constrains it.

A system that is not honest about its limits invites use it cannot support.

Four things not to do with it

Map levels to pay bands

The scale will not bear that weight, least of all between two different domains.

Compare across domains

A level 3 in cryptography and a level 3 in OSINT are not the same amount of work. There is no exchange rate.

Read a self-rating as performance

It is a person describing their own competence against written criteria, which is a different thing.

Quote a stale level

Check the assessed date and the last-practiced date before using any profile in a decision.

Used for what it measures, this is the most defensible record of capability the laboratory has. Used for anything else, it will mislead.